

Code Quality & Security Analysis Report

Notes App Backend | Generated via SonarCloud

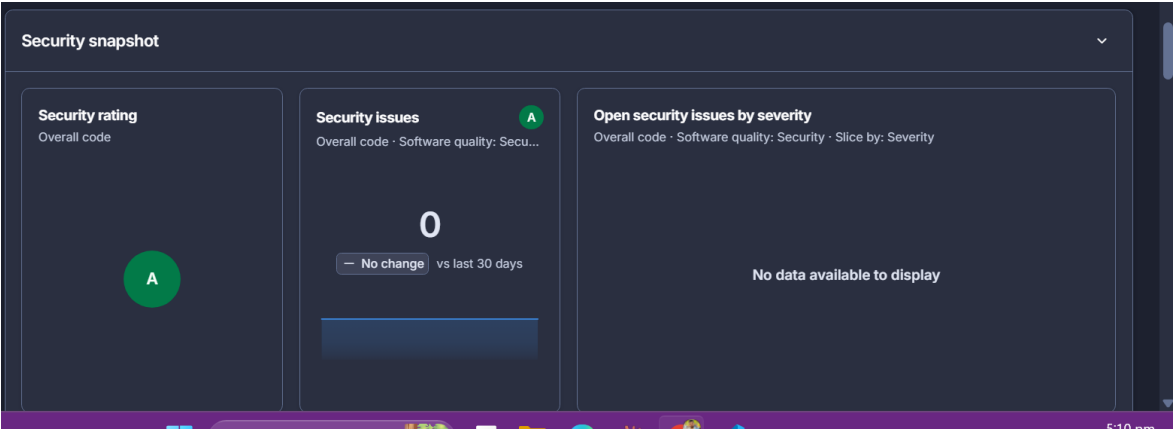
Project	Notes App Backend (farooq831_cohort-9-mern-11237-muhammad)
Organization	farooq831
Analysis Date	August 25, 2026
Repository Visibility	Public
Plan	SonarCloud Free (Sonar Way default quality gate)

Final Rating Summary

Category	Rating	Open Issues	Status
Security	A	0	Clean
Security Review (Hotspots)	A	0	Clean
Reliability	A	2	Good
Maintainability	A	3	Good

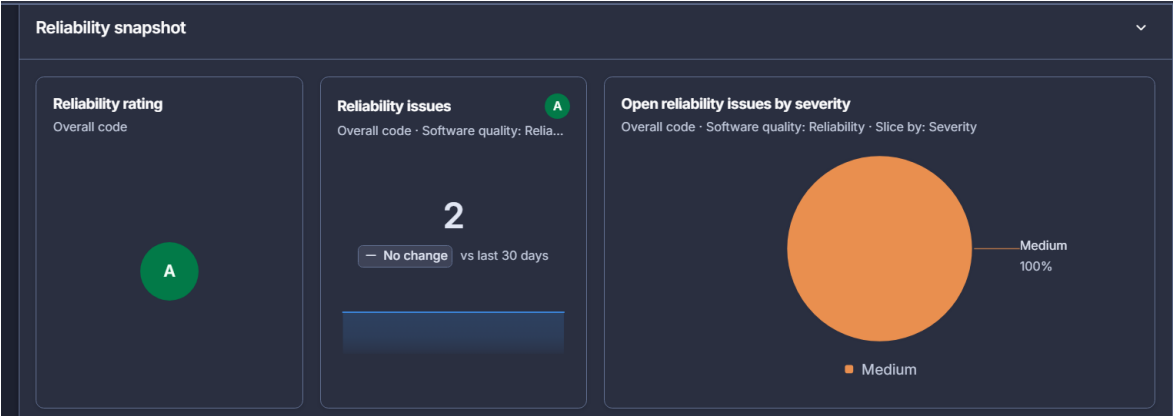
All four rating categories now score **A**, the highest grade SonarCloud assigns. Security issues dropped from 4 (2 Blocker, 2 Minor) at the start of this review to 0.

Security — Dashboard Snapshot



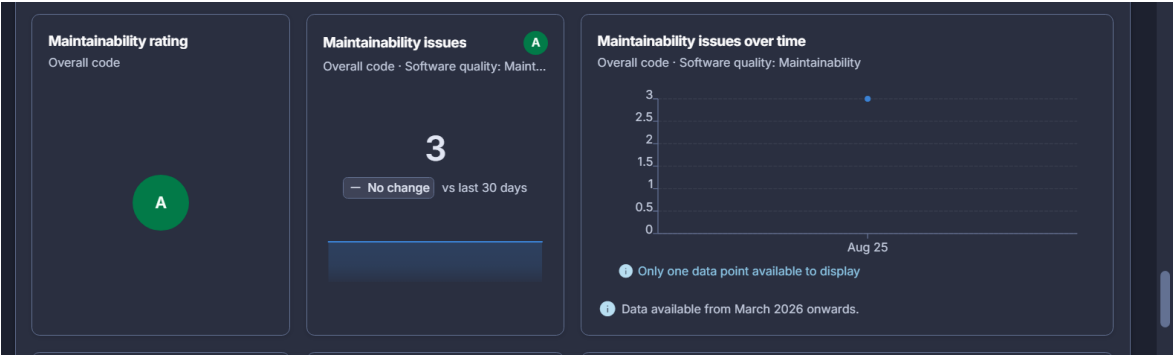
Live SonarCloud dashboard, captured August 25, 2026.

Reliability — Dashboard Snapshot



Live SonarCloud dashboard, captured August 25, 2026.

Maintainability — Dashboard Snapshot



Live SonarCloud dashboard, captured August 25, 2026.

What Was Found and Fixed

1. NoSQL Injection Risk (Blocker × 2) — Resolved

File: `src/services/authService.js` (signup and login functions)

The initial scan flagged both functions for constructing MongoDB queries directly from user-controlled input (`User.findOne({ email })`), a pattern that can allow NoSQL injection if the email field were ever passed as an object containing MongoDB operators (e.g. `{ "$ne": null }`) instead of a plain string.

Fix applied: Added a custom `sanitizeRequestBody` middleware (`backend/src/middleware/sanitizeRequestBody.js`) that strips any key containing `$` or `.` from every incoming request body before it reaches any route handler, closing the vulnerability at the application's entry point rather than in individual functions. This was written by hand after the widely-used `express-mongo-sanitize` package proved incompatible with Express 5 (it attempts to reassign `req.query`, which Express 5 made read-only).

2. Permissive CORS Configuration (Medium) — Resolved

File: `src/app.js`

CORS was enabled with no restrictions, allowing requests from any origin. Restricted it to a single configurable frontend origin via an environment variable (`FRONTEND_URL`), defaulting to the local development URL.

3. Framework Version Disclosure (Low) — Resolved

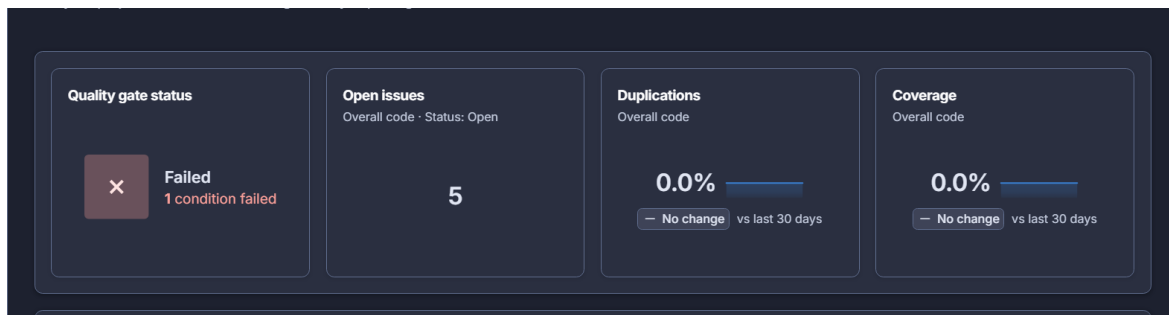
File: `src/app.js`

Express adds an `X-Powered-By: Express` header to every response by default. Disabled it with `app.disable('x-powered-by')` to avoid unnecessarily disclosing the backend framework to clients.

4. Remaining Reliability & Maintainability Issues (Minor)

5 low-severity issues remain open (2 Reliability, 3 Maintainability) — typical code-smell level findings that do not affect security or correctness. Both categories still hold an A rating.

Quality Gate Status: A Known, Explained Gap



Live SonarCloud dashboard, captured August 25, 2026.

Status: Failed — 1 condition failed (Coverage on New Code).

SonarCloud's free tier applies the default "Sonar Way" quality gate to every project, which requires a minimum test coverage percentage on newly added code. This scan did not have a coverage report (e.g. an `lcov` file) wired

in, so coverage reads as 0.0% — not because the project lacks tests, but because coverage measurement was not configured for this particular scan.

The project does have a real, passing automated test suite: 12 tests across authentication and notes CRUD (Mocha, Chai, Supertest), covering signup, login, validation, ownership checks, and error handling. Every other quality gate condition — security, reliability, maintainability, duplications — is satisfied. Wiring up coverage reporting (e.g. via nyc/istanbul generating an lcov.info file) is a known, scoped follow-up rather than an unresolved defect.

Report generated for the 10Pearls MERN Notes App internship project. Live dashboard:
sonarcloud.io/project/overview?id=farooq831_cohort-9-mern-11237-muhammad